

Evaluación de los riesgos en materia de seguridad e ISO 27002

Evaluación de los riesgos en materia de seguridad

El objetivo principal de la gestión de riesgo es determinar el máximo nivel permitido de riesgos que se está dispuesto a tolerar, así como la definición de controles pertinentes para proteger los recursos de las vulnerabilidades. Asimismo, es una construcción propia que permite lograr niveles de protección previniendo la ocurrencia de amenazas y, asegura los tres pilares del SGSI (disponibilidad, integridad y confidencialidad).

ISO 27001	ISO 27005
Procesos del SGSI	Proceso de Gestión del Riesgo de Seguridad de la Información
Planificar	• Establecimiento del contexto • Evaluación del riesgo • Planificación del tratamiento • Aceptación del tratamiento
Hacer	Implementación del plan de tratamiento del riesgo
Verificar	Seguimiento (<i>monitoring</i>) y revisión continuos de los riesgos
Actuar	Mantenimiento y mejora del Proceso de Gestión del riesgo de seguridad de la información

Figura 1: Gestión de riesgos. Fuente: elaboración propia.

Según la ISO/IEC 2701:

- Definir el enfoque de evaluación de riesgo:
 - Identificar una metodología de evaluación de riesgo.
 - Desarrollar criterios para la aceptación de riesgos e identificar los niveles de riesgos aceptables.
- Identificar los riesgos:
 - Identificar los activos.
 - Identificar las amenazas.
 - Identificar las vulnerabilidades.
 - Identificar los impactos de la pérdida de CIA sobre los activos.
- Analizar y evaluar los riesgos:

- Evaluar el impacto en las actividades del negocio, teniendo en cuenta las consecuencias de pérdida de CIA de los activos.
- Evaluar la posibilidad real de que ocurra una falla de seguridad, teniendo en cuenta las amenazas, vulnerabilidades y los impactos sobre los activos y controles implementados.
- Estimar los niveles de riesgos.
- Determinar si se acepta el riesgo o si es necesario su tratamiento a partir de criterios establecidos.
- Resultados de la evaluación:
 - Los resultados serán una guía y determinarán la acción de una gestión apropiada, así como las propiedades de la gestión de los riesgos de seguridad de la información y la selección de la implementación de controles para protegerla de estos riesgos.
 - Puede ser necesario realizar varias veces el proceso de evaluación de los riesgos y seleccionar los controles para cubrir diferentes partes de la organización o sistemas de información.
- Identificar y evaluar las opciones de tratamiento de riesgo:
 - Aplicar los controles (reducir los riesgos).
 - Aceptar los riesgos.
 - Evitar los riesgos.
 - Transferir riesgos.
- Seleccionar los objetivos de control y los controles para el tratamiento de riesgos.
- Obtener la aprobación de la alta dirección sobre los riesgos residuales.
- Obtener la autorización de la alta dirección para implementación y operar el SGSI.
- Confeccionar un SOA (Declaración de Aplicabilidad – *Statement of Applicability*).

ISO/IEC 27002 – Áreas de la Seguridad

Controles ISO/IEC 27002:2013

ANEXO A: 14 Dominios de ISO 27002:2013 y 35 de objetivos de control	
A.5. Políticas de SI (1)	A.12. Seguridad de las operaciones (7)
A.6. Organización de la seguridad de la información (2)	A.13. Seguridad de las comunicaciones (2)
A.7. Seguridad de los recursos humanos (3)	A.14. Adquisición, desarrollo, mantenimiento del sistema (3)
A.8. Gestión de activos (3)	A.15. Relación con los proveedores (2)
A.9. Control de accesos (4)	A.16. Gestión de incidentes de la seguridad (1)
A.10. Criptografía (1)	A.17. Aspectos de SI de la Continuidad del negocio (2)
A.11. Seguridad física y Medioambiental (2)	A.18. Cumplimiento (2)

Figura 2: Dominios ISO/IEC 27002. Fuente: elaboración propia.

Dominio I – Políticas de Seguridad de la Información

A.5.1 Gestión de la Gerencia para la seguridad de la información

Objetivo: brindar respaldo y dirección a la gestión para la seguridad de la información de acuerdo a los objetivos del negocio, leyes y regulaciones aplicables.

Dominio II - Organización de la seguridad de la información

A.6.1 Organización interna

Objetivo: establecer un marco de trabajo de gestión para iniciar y controlar la implementación y operación de la seguridad de la información dentro de la organización.

A.6.2 Equipos móviles y trabajo a distancia

Objetivo: garantizar la seguridad del trabajo a distancia y del uso de los equipos móviles.

Dominio III - Seguridad de los Recursos Humanos

A.7.1. Antes del ingreso

Objetivo: asegurar que los empleados y contratistas se conozcan y cumplan sus responsabilidades sobre seguridad de la información.

A.7.2 Durante el trabajo

Objetivo: garantizar que los trabajadores y los contratistas sean conscientes y cumplan con las responsabilidades de la seguridad de la información.

A.7.3 Término y cambio de empleo

Objetivo: proteger los intereses de la organización como parte del proceso de cambio o término del empleo.

Dominio IV – Gestión de activos

A.8.1 Responsabilidades sobre los activos

Objetivo: identificar los activos de la organización y definir las responsabilidades adecuadas de protección.

A.8.2 Clasificación de la información

Objetivo: garantizar que la información reciba un nivel adecuado de protección de acuerdo a su importancia dentro de la organización.

A.8.3 Gestión de los medios de comunicación

Objetivo: prevenir la divulgación, modificación, retiro o destrucción no autorizada de la información almacenada en los medios de comunicación.

Dominio V – Control de accesos

A.9.1 Requisitos del negocio sobre control del acceso

Objetivo: limitar el acceso a la información y a los servicios de procesamiento de la información.

A.9.2 Gestión del acceso del usuario

Objetivo: garantizar el acceso al usuario autorizado para evitar el acceso no autorizado a los sistemas y servicios.

A.9.3 Responsabilidades del usuario

Objetivo: hacer a los usuarios responsables de salvaguardar la autenticidad de su información.

A.9.4 Control de acceso a sistemas y aplicaciones

Objetivo: evitar el acceso no autorizado a los sistemas y aplicaciones.

Dominio VI – Criptografía

A.10.1 Controles criptográficos

Objetivo: asegurar el uso adecuado y efectivo de la criptografía para proteger la confidencialidad, autenticidad y/o integridad de la información.

Dominio VII – Seguridad física y medioambiental

A.11.1 Áreas seguras

Objetivo: evitar acceso físico no autorizado, daño e interferencia a la información e instalaciones de procesamiento de la información de la organización.

A.11.2 Equipos

Objetivo: evitar la pérdida, daño, robo o actos en los que se comprometan activos y la interrupción de las operaciones de la organización.

Dominio VIII – Seguridad de las operaciones

A.12.1 Procedimientos y responsabilidades operaciones

Objetivo: prevenir accesos físicos no autorizados, daño e interferencia en la información de las y en sus servicios de procesamiento.

A.12.2 Protección contra el *malware*

Objetivo: garantizar que la información y las instalaciones de procesamiento de la información estén protegidos contra el malware.

A.12.3 Backup

Objetivo: proteger la información contra la pérdida.

A.12.4 Logeo y monitoreo

Objetivo: registrar eventos y generar evidencias.

A.12.5 Control del software operativo

Objetivo: garantizar la integridad de los sistemas operativos.

A.12.6 Gestión de las vulnerabilidades técnicas

Objetivo: evitar la explotación de las vulnerabilidades técnicas.

A.12.7 Consideraciones de las auditorías sobre los sistemas de información

Objetivo: minimizar el impacto de las actividades de las auditorías en los sistemas operacionales.

Dominio IX – Seguridad de las comunicaciones

A.13.1 Gestión de la seguridad de las redes

Objetivo: garantizar la protección de la información en las redes y de sus instalaciones de procesamiento.

A.13.2. Transferencia de la información

Objetivo: mantener la seguridad de la información transferida dentro de la organización y con cualquier entidad externa.

Dominio X – Adquisición, desarrollo y mantenimiento de sistemas

A.14.1 Requisitos de seguridad de los sistemas de información

Objetivo: garantizar que la seguridad de la información forme parte integral de los sistemas de información a lo largo de todo el ciclo de vida. Esto incluye los requisitos del sistema de información que proveen servicios mediante las redes públicas.

A.14.2 Seguridad en los procesos del programa de desarrollo y soporte

Objetivo: garantizar que se diseñe e implemente la seguridad de la información dentro del ciclo del programa de desarrollo de los sistemas de la información.

A.14.3 Datos de prueba

Objetivo: garantizar la protección de los datos utilizados para la verificación.

Dominio XI – Relación con proveedores

A.15.1 Seguridad de la información en las relaciones con los proveedores

Objetivo: garantizar la protección de los activos de la información a los que los proveedores tiene acceso.

A.15.2 Gestión de la prestación del servicio por parte del proveedor

Objetivo: mantener un nivel acordado de seguridad de la información y de la prestación del servicio alineado a los acuerdos del proveedor.

Dominio XII – Gestión de los incidentes de la SI

A.16.1 Gestión de los incidentes de la seguridad de la información y la mejora

Objetivo: garantizar una aproximación consistente y efectiva a la gestión de los incidentes de seguridad de la información, incluyendo la comunicación sobre los eventos y debilidades de la seguridad.

Dominio XIII – Aspectos de SI de la continuidad del negocio

A.17.1 Continuidad de la seguridad de la información

Objetivo: la continuidad de la seguridad de la información debe estar incorporada en los sistemas de gestión de la continuidad del negocio de la organización.

A.17.2 Redundancias

Objetivo: garantizar la disponibilidad de las instalaciones de procesamiento de la información.

Dominio XIV – Cumplimiento

A.18.1 Cumplimiento de los requisitos legales y contractuales

Objetivo: evitar el incumplimiento de las obligaciones legales, regulatorias o contractuales relacionadas a la seguridad de la información y a cualquier requisito de seguridad.

A.18.2 Revisiones de la seguridad de la información

Objetivo: garantizar que la seguridad de la información sea implementada y operada de acuerdo a las políticas y procedimientos organizacionales.

Referencias

IRAM ISO/IEC 2700:2013 - Sistemas de gestión de la seguridad de la información:

- En español: <http://www.iso27000.es/>
- En inglés: <http://www.iso27001security.com/>

ISO/IEC 27000 en iso.org:

- <https://www.iso.org/obp/ui/#iso:std:iso-iec:27000:ed-3:v1:en>